Section 08

Industrial Security (Master)

IS Security

Section 08 – Research Methods and Seminar Work

Research Methods and Seminar Work

Lecture Notes

Department of Computer Science

Outline – Section 08

Learning Objectives

By the end of this section you will be able to

- Distinguish industrial-security research from product-development work.
- Choose an appropriate research method (case study, measurement, experiment, design science).
- Build a reproducible artefact – dataset, tool, or testbed.
- Publish findings ethically and survive responsible-disclosure timelines.
- Prepare a seminar talk that withstands an academic audience.

1

What is OT Security Research?

Three Research Cultures

Academic
peer-review, novelty

Vendor R&D
patentable, productisable

Practitioner
war-stories, playbooks

All three are valid

The best OT-security work blends all three. Pure academia misses operations. Pure vendor work is constrained by IP. Pure war stories don't generalise.

Source: Wieringa, R. *Design Science Methodology for IS and SE*, Springer, 2014.

Choosing a Method

Method	Question it answers	Typical OT topic
Case study	“What happened, in detail?”	TRITON forensic walk-through
Measurement	“How big / how many?”	Shodan census, attack frequency
Experiment	“Does X cause Y?”	latency of intrusion detection
Design science	“Build an artefact, evaluate it.”	new IDS rule set, new protocol fuzzer
Theory building	“What explains the pattern?”	threat actor TTPs across campaigns

2

Reproducible Artefacts

What “Reproducible” Looks Like

- Code under version control with a permissive license.
- Data with provenance, sized for download (<50 GB), and (if sensitive) anonymised.
- Containerised execution environment (Docker, Nix).
- Step-by-step README that a third party can run cold.
- Pinned dependency versions.

What kills reproducibility in ICS

Closed-source dependencies, equipment available only at one university, proprietary protocol stacks, NDAs on the data set.

Source: ACM Artifact Review and Badging policy, 2020.

Public ICS Datasets

- iTrust SWaT & WADI testbeds
- Mississippi State gas pipeline
- ICS-CERT advisory corpus
- Conpot honeypot logs
- DARPA OpTC, CIDDS-001
- netresec.com PCAP archive

Source: Goh, J. et al., SWaT testbed (SUTD iTrust); Morris, T. et al., gas pipeline dataset (MSU); MITRE D3FEND.

Building a Testbed

Real PLC (spare) ↔ Software emulator ↔ Process simulator ↔ Attacker host

Cost-effective combos

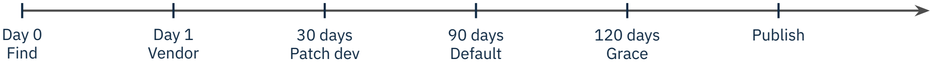
OpenPLC + ScadaBR + Simulink + Kali on a single laptop costs nothing and reproduces most academic-paper experiments.

Source: OpenPLC; Mathworks Simulink; ICS Village curriculum.

3

Ethics and Publication

Disclosure Timelines for Research



ICS adjusts the clock

For ICS, 90/30 (Google Project Zero) is too aggressive – coordinated rollouts take longer. 180/60 is more typical; document any deviation in the disclosure email.

Source: Google Project Zero policy; ISO/IEC 29147:2018; CERT/CC vulnerability handling policy.

Where to Publish

USENIX Security, IEEE S&P, NDSS, CCS

ACSAC, ESORICS, RAID

WOOT, CSCS (ICS-focused)

S4 / DEF CON / BlackHat / Hardwear.io

IEEE Tx Smart Grid, Tx Industrial Inf.

Computers & Security, IJCIP

The Acknowledgements Section

- Name the vendor PSIRT contact if they cooperated.
- Credit the coordinating CERT (BSI / CISA / JPCERT).
- Cite the disclosure timeline (date sent, date acknowledged, date patched).
- If anonymising the asset owner, say so – and explain why.

Caution

A paper that publishes exploit details before patch availability burns the relationship – with that vendor and the wider community.

4

The Seminar Talk

Structure of a Seminar Talk

1. One-slide problem statement (90 seconds)
2. Why prior work falls short
3. Method or artefact
4. Evaluation – one quantitative chart
5. Limitations + threats to validity
6. Conclusions + next steps

Questions to Expect

- “How did you handle the obvious confound *X*?”
- “What is the smallest realistic deployment that would benefit from this?”
- “Did you measure the operational cost?”
- “How does your approach generalise to vendor *Y*?”
- “What does the vendor say?”

Rehearse the hostile question

The strongest defence is a slide in your back pocket that answers the question before it is asked.

Writing Habits

- One claim per paragraph; one paragraph per claim.
- Numbers in the abstract; jargon out.
- Reproducibility artifacts as a single zenodo / archive.org capture.
- Pre-print on arXiv after vendor agreement.
- Track citations – they show whether the work is being used.

Common Pitfalls

- Confusing CVE-count with security maturity.
- Generalising from a single vendor or single sector.
- Datasets without ground truth.
- Tools that only work on the author's lab.
- "Future work" that the authors will never do.

Caution

A paper that promises 12 lines of "future work" usually delivers zero. Pick one and finish it instead.

Summary – Section 08

★ Key Takeaway: Doing OT-security research well

- Pick a method that matches the question (case, measurement, experiment, design science).
- Build reproducible artefacts – code, data, container, README.
- Coordinate disclosure on ICS-realistic timelines (180/60 typical).
- Publish where ICS-aware reviewers read; structure talks for a hostile audience.
- Avoid the well-known pitfalls – CVE-count, single-vendor generalisations, no ground truth.

References – Section 08

- Wieringa, R. *Design Science Methodology for Information Systems and Software Engineering*, Springer, 2014.
- Runeson, P., Höst, M. “Guidelines for conducting and reporting case study research in software engineering”, *Empirical Software Engineering*, 2009.
- ACM. *Artifact Review and Badging* policy, 2020.
- Goh, J., Adepu, S., Junejo, K.N., Mathur, A. SWaT testbed papers, SUTD iTrust.
- Morris, T., Gao, W. Industrial Control System (ICS) attack/defense datasets, Mississippi State University.
- Conpot project. *Conpot* ICS/SCADA honeypot.
- ISO/IEC 29147:2018. *Vulnerability disclosure*.
- ISO/IEC 30111:2019. *Vulnerability handling processes*.
- Google Project Zero. *Vulnerability Disclosure FAQ*.
- CERT/CC. *Vulnerability Disclosure Policy*.
- USENIX Security, IEEE S&P, NDSS, CCS conference websites for ICS-related submissions.
- Smith, R. *Writing Science*, Oxford, 2012 (for technical writing habits).

End of Section 08

Research Methods and Seminar Work

Questions and discussion

IS Security